Diseño de Arquitectura de Solución

Sistema de Banca por Internet – BP

Arquitecto: Juan Carlos Estévez Hidalgo

Propongo una arquitectura de microservicios sobre Amazon EKS, detrás de API Gateway con AWS WAF, desplegada con recuperación ante desastres. La autenticación usa OAuth 2.0 con Authorization Code + PKCE; el onboarding facial usa Amazon Rekognition; los eventos de dominio viajan por SNS + SQS con Transactional Outbox; la auditoría es inmutable y los clientes frecuentes se atienden con Cache-Aside sobre Redis.

Atributo	Objetivo (supuesto)	Cómo se atiende
Disponibilidad	99,95 % mensual	Multi-AZ en todo componente y auto-healing (sección 7)
DR	RTO 1 h, RPO 5 min (a validar con el negocio)	Replicación continua a us-east-1, Pilot Light (D16)
Latencia	p95 menor a 400 ms sin contar el Core	Cache-Aside y paginación por cursor (sección 5)
Seguridad y auditoría	Defensa en profundidad y registro inmutable	Secciones 4, 5 y 7
Escalabilidad	Hasta 3 veces el volumen inicial	HPA, Cluster Autoscaler y servicios gestionados

Marco normativo

Estos son los elementos que considero relevantes para una entidad financiera en Ecuador. La interpretación final, en especial sobre biometría y transferencia internacional de datos, corresponde a Cumplimiento y Asesoría Jurídica de BP.

Norma	Aplicación	Reflejo en la arquitectura
LOPDP (R.O. Suplemento 459, 26-may-2021), arts. 8, 25 y 26	Consentimiento explícito; el rostro es dato biométrico (categoría especial); derechos del titular; transferencia internacional.	Consentimiento en el onboarding, retención mínima de imágenes, cifrado con KMS, biometría de login solo en el dispositivo, validación legal de la región AWS.
COMF arts. 62 num. 30 y 63; JPRF Libro I (Tít. II Cap. VII; Cap. XXV art. 4)	Seguridades adecuadas y gestión integral de riesgos.	MFA, límites transaccionales, notificación de cada movimiento.
Codificación SB, Libro I, Tít. IX, Cap. V, Secc. VIII	Seguridad de la información y continuidad.	Controles por capa, bitácora inmutable, DR probado.
Circular SB-INRE-2022-0021-C	Documentación previa a ofrecer servicios por canales electrónicos.	Este documento y los diagramas C4 como descripción técnica.
Ley de Comercio Electrónico	Validez de los mensajes de datos.	Bitácora con huella, fecha y trace-id.
PCI DSS, ISO 27001, OWASP ASVS y API Top 10; RFC 6749, 7636, 8252 y 9700	Estándares técnicos de seguridad y OAuth.	Tokenización, pruebas SAST/DAST, Authorization Code + PKCE.

Modelo C4: contexto, contenedores y componentes

Contexto (Figura 1). El sistema Banca por Internet BP atiende a tres actores: Cliente, Nuevo cliente y Auditor. Se integra con el proveedor de identidad, la plataforma Core, el sistema complementario, la red interbancaria, el servicio de correo (Amazon SES o el existente en BP), SMS/Push (Amazon SNS) y Amazon Rekognition.

Contenedores (Figura 2). Dos clientes (SPA Angular en CloudFront + S3 y app Flutter) entran solo por API Gateway + WAF. Dentro de EKS corren Keycloak y seis microservicios Spring Boot: Datos Básicos, Movimientos, Transferencias, Onboarding, Notificaciones y Auditoría. Se apoyan en SNS + SQS (con DLQ), ElastiCache Redis, Aurora PostgreSQL y DynamoDB + S3 Object Lock. Decisiones: D1 a D6, D9, D12.

Componentes (Figura 3). Detallo Transferencias (escritura) y Movimientos (lectura con caché), con arquitectura hexagonal (D14): el dominio no depende de frameworks y todo acceso externo pasa por puertos y adaptadores.

Patrón	Dónde	Qué resuelve
Saga orquestada y compensación	SagaOrchestrator	Consistencia entre Core, interbancaria y BD sin transacciones distribuidas (D13)
Idempotency-Key	IdempotencyService	Evita doble débito ante reintentos
Transactional Outbox	OutboxPublisher	Evento y negocio en una sola transacción, sin pérdida
Circuit Breaker, Retry, Bulkhead	Adaptadores del Core e interbancaria	No saturar sistemas externos y degradar con elegancia
Cache-Aside y CQRS de lectura	Movimientos	Baja latencia y menor carga al Core (D11)
Anti-Corruption Layer	Adaptadores externos	Protege el dominio de cambios en sistemas existentes

Comunicaciones: HTTPS (TLS 1.2/1.3) con JWT desde los clientes; API Gateway llega a los servicios por VPC Link; los servicios usan REST con credenciales de servicio hacia el Core y mTLS hacia la interbancaria; acceso a Aurora, Redis, SNS y SQS con roles IAM por servicio (IRSA) y secretos en Secrets Manager.

Figura 1. C4 Nivel 1 - Contexto

C4 Nivel 1 - Diagrama de Contexto

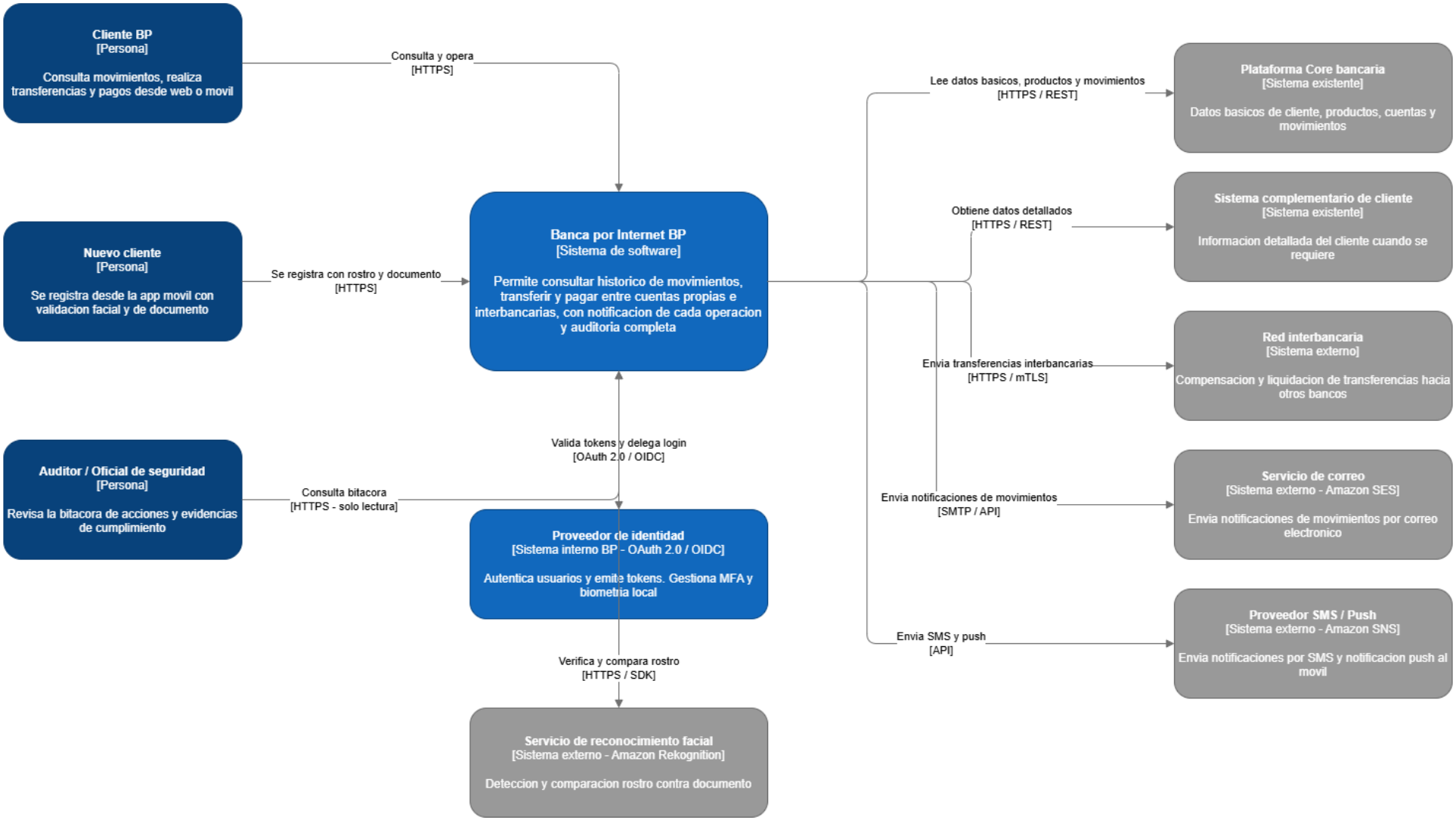


Figura 2. C4 Nivel 2 - Contenedores

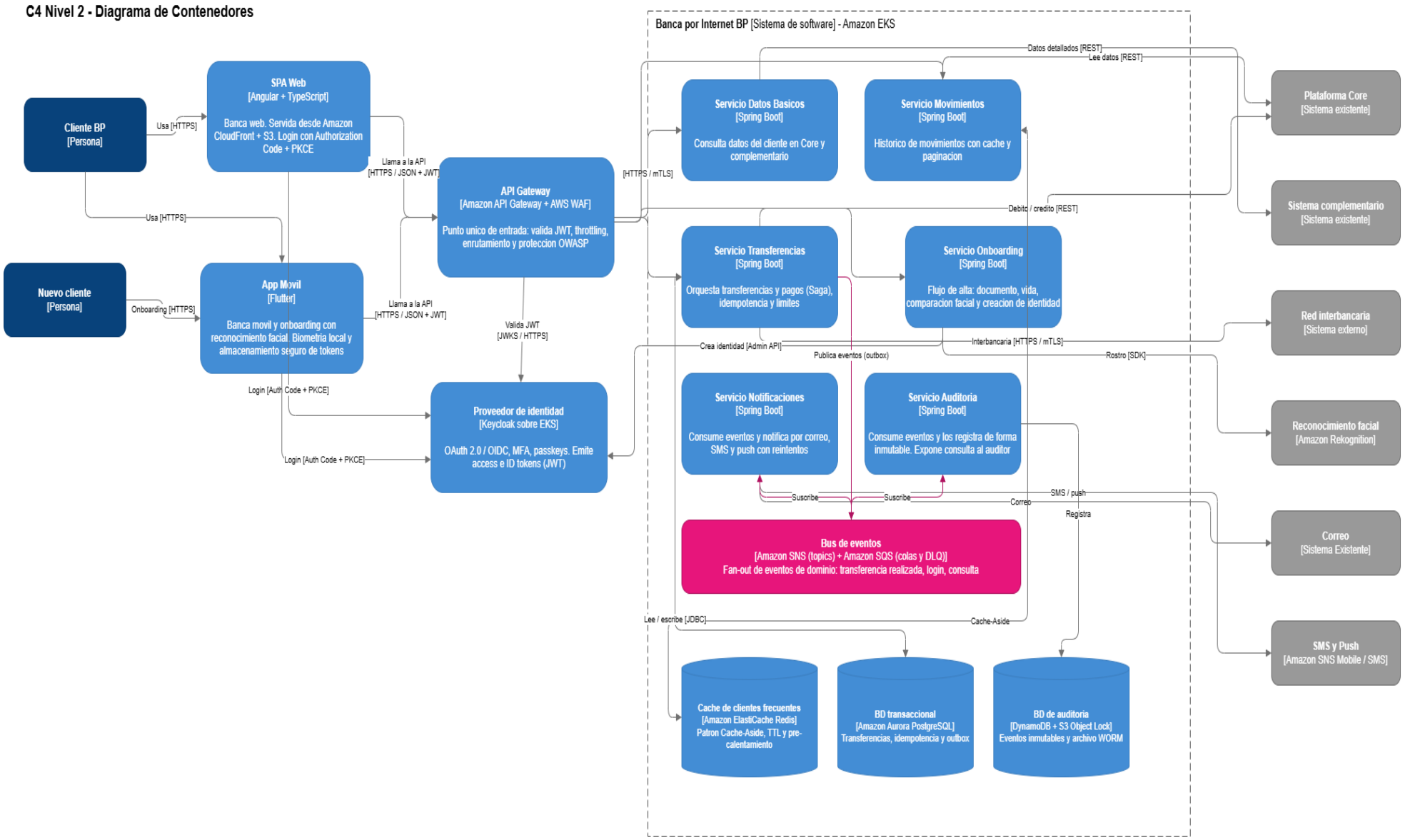
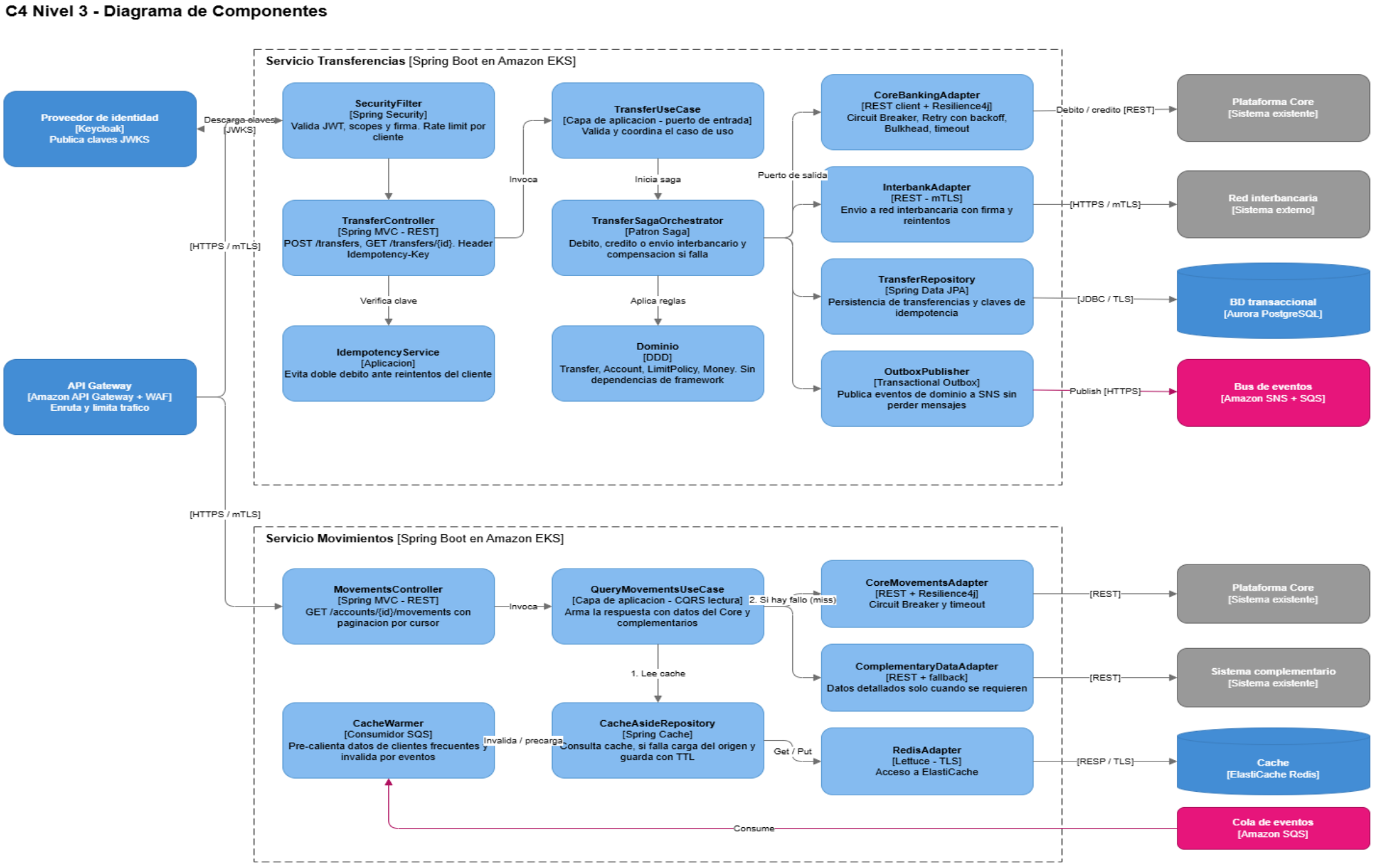


Figura 3. C4 Nivel 3 - Componentes (Transferencias y Movimientos)



Autenticación y onboarding

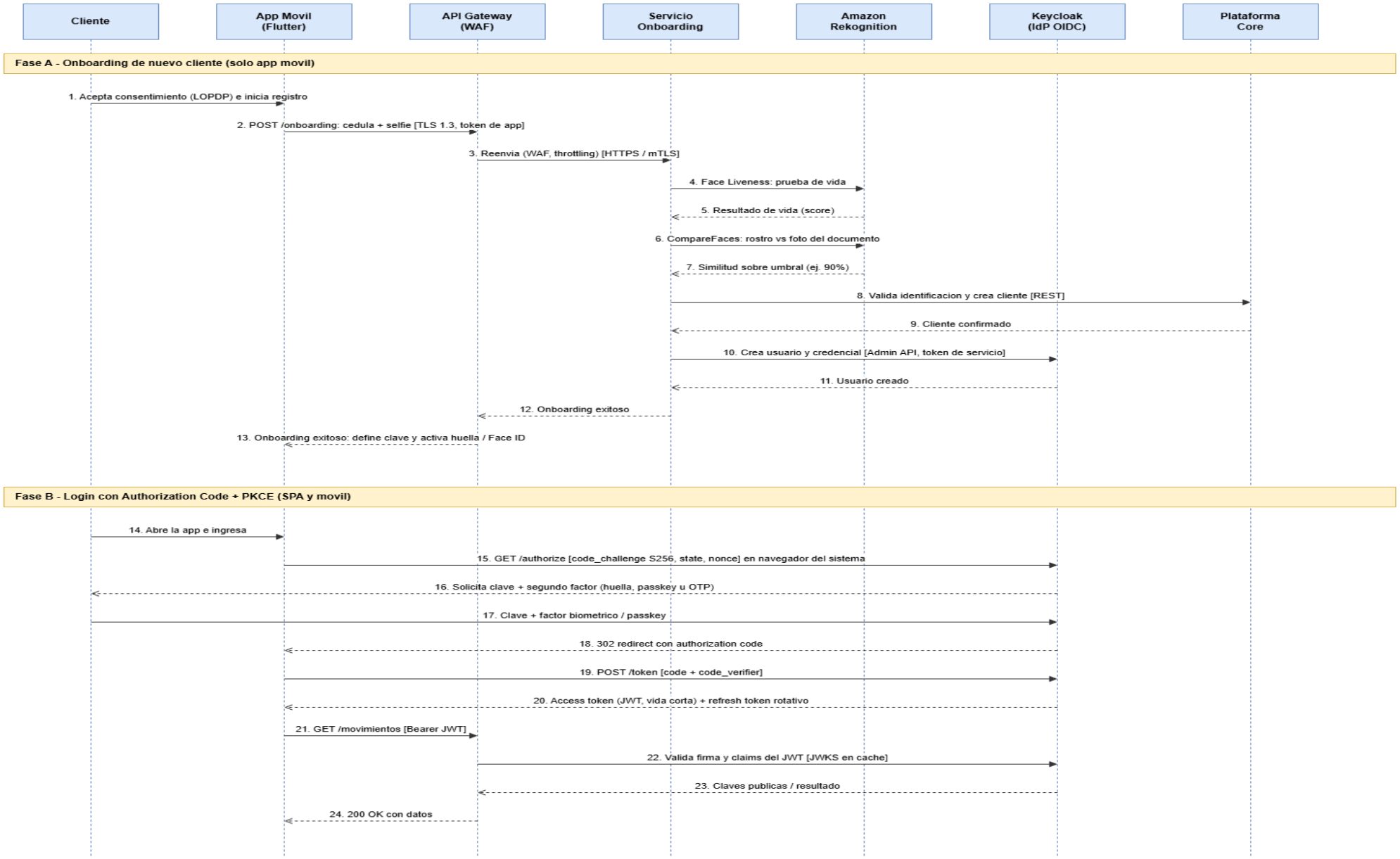
Flujo OAuth 2.0. Uso Authorization Code + PKCE (S256) en la SPA y en la app móvil, que abre el navegador del sistema (RFC 8252). Descarto Implicit y Password por estar desaconsejados (D7). Client Credentials se usa solo entre servicios.

Tokens y sesión. Access token JWT de 5 a 10 minutos validado con JWKS; refresh token rotativo con detección de reutilización, guardado en Keychain/Keystore (en la SPA los tokens viven solo en memoria); step-up con segundo factor para transferencias sobre un umbral.

Ingreso posterior al onboarding. Usuario y clave como primer factor; huella o Face ID del dispositivo para desbloquear el refresh token (la biometría no sale del dispositivo); passkeys (FIDO2) como segundo factor; OTP por app o SMS como contingencia. Proveedor: Keycloak en EKS (D6).

Onboarding (Figura 4, fase A). (1) Consentimiento explícito. (2) La app captura cédula y selfie con prueba de vida y las envía al Servicio Onboarding por API Gateway. (3) Rekognition Face Liveness valida que es una persona real. (4) CompareFaces compara con la foto del documento sobre un umbral definido por Riesgos. (5) Se valida o crea el cliente en el Core. (6) El servicio crea el usuario en Keycloak por su Admin API. (7) El cliente define su clave y activa su biometría local; desde ahí usa la fase B (login). Las imágenes se procesan en almacenamiento temporal cifrado y se eliminan al terminar; los intentos se limitan por documento, dispositivo e IP (D8).

Figura 4. Secuencia: onboarding facial y login con Authorization Code + PKCE

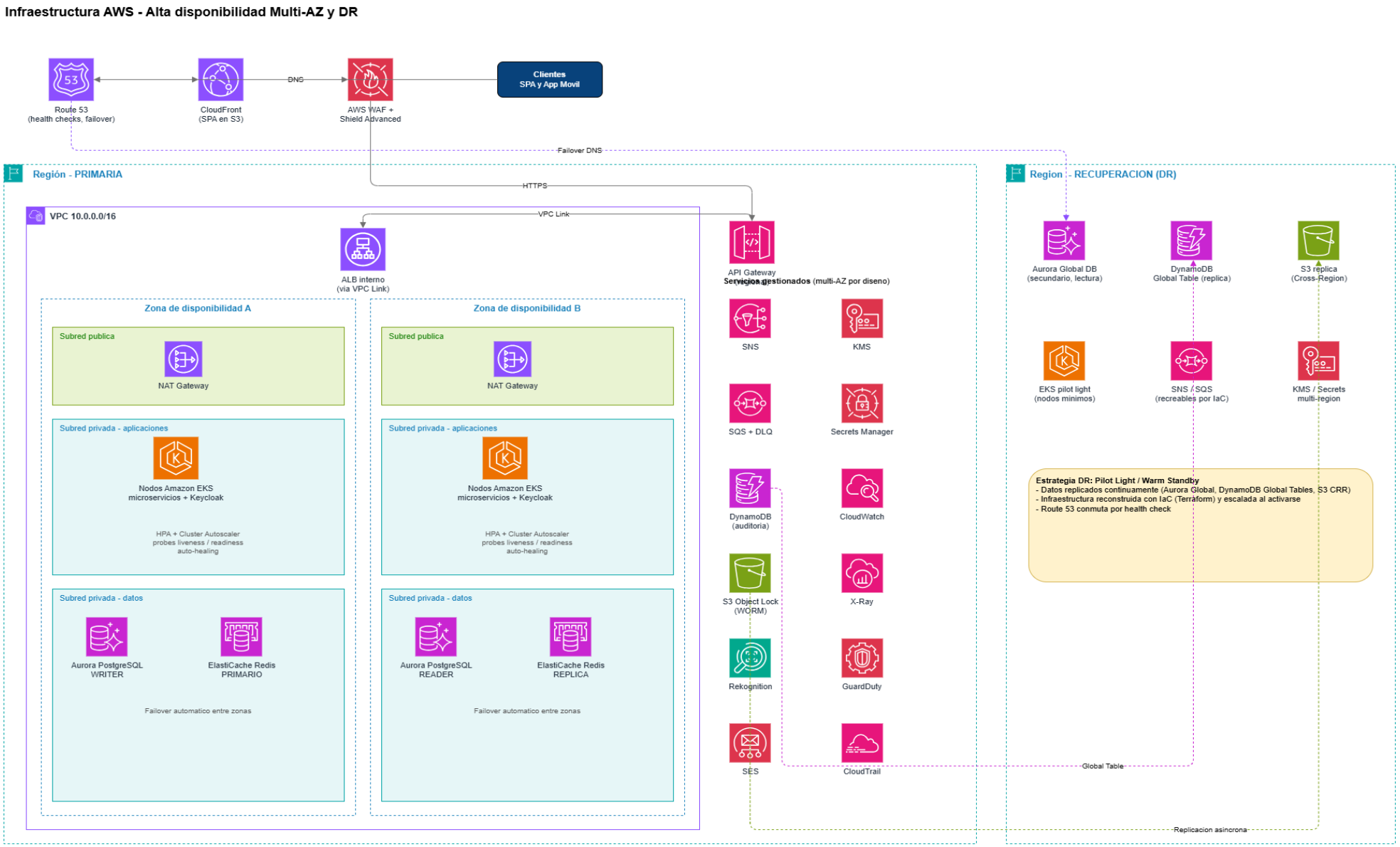


Auditoría y clientes frecuentes

Auditoría inmutable (Figura 5, carril 2). Transferencias escribe negocio y evento en la misma transacción de Aurora (Outbox); un relay publica en SNS, que reparte a colas SQS independientes (auditoría, caché y notificaciones), cada una con DLQ. El Servicio Auditoría consume de forma idempotente y escribe en DynamoDB solo con inserciones (cliente + marca de tiempo). Streams y Firehose archivan en S3 con Object Lock en modo compliance, y el auditor consulta con Athena. Cada evento registra quién, qué, cuándo, desde dónde, resultado y trace-id (D10).

Clientes frecuentes (Figura 5, carriles 1 y 3). Cache-Aside sobre Redis: si hay acierto se responde al instante; si no, se consulta el Core o Aurora y se guarda con TTL. El CacheWarmer invalida la clave cuando llega un evento de transferencia, así el cliente no ve saldos desactualizados. Cada hora, EventBridge Scheduler y Lambda calculan los clientes más activos y los pre-calientan. Si Redis falla, el servicio degrada hacia el origen con circuit breaker (D11).

Figura 5. Auditoría inmutable y caché para clientes frecuentes



Integración y microservicios

API Gateway: autorizador JWT, validación de esquemas OpenAPI, throttling por cliente, WAF con reglas OWASP y versionado de rutas; los servicios quedan privados tras VPC Link (D3).

Servicios agregados al requerimiento: Onboarding (aísla el flujo facial), Notificaciones (cumple la norma de informar cada movimiento sin acoplar el negocio al canal) y Auditoría. Futuros servicios (pagos de servicios, límites, antifraude) se suscriben al mismo bus de eventos sin tocar los actuales.

Integraciones externas: el Core y el complementario se consumen por REST con capa anticorrupción, timeouts cortos, circuit breaker y respuesta desde caché si el origen falla. La interbancaria usa mTLS, idempotencia y confirmación asíncrona: la transferencia queda pendiente hasta la liquidación y la Saga compensa si es rechazada. Notificaciones usa al menos dos canales (correo y SMS/push) con reintentos y backoff; si uno falla, el otro no se bloquea (D15).

Transferencia: el cliente envía la solicitud con Idempotency-Key; la Saga valida límites, debita en el Core y acredita en cuenta propia o envía a la interbancaria; se guarda estado y evento de outbox; el relay publica y se disparan auditoría, notificación e invalidación de caché; si un paso falla, se compensa.

Alta disponibilidad, DR, seguridad y monitoreo

La Figura 6 muestra la región primaria con su VPC en 2 zonas de disponibilidad (extensible a 3), los servicios gestionados y la región de DR.

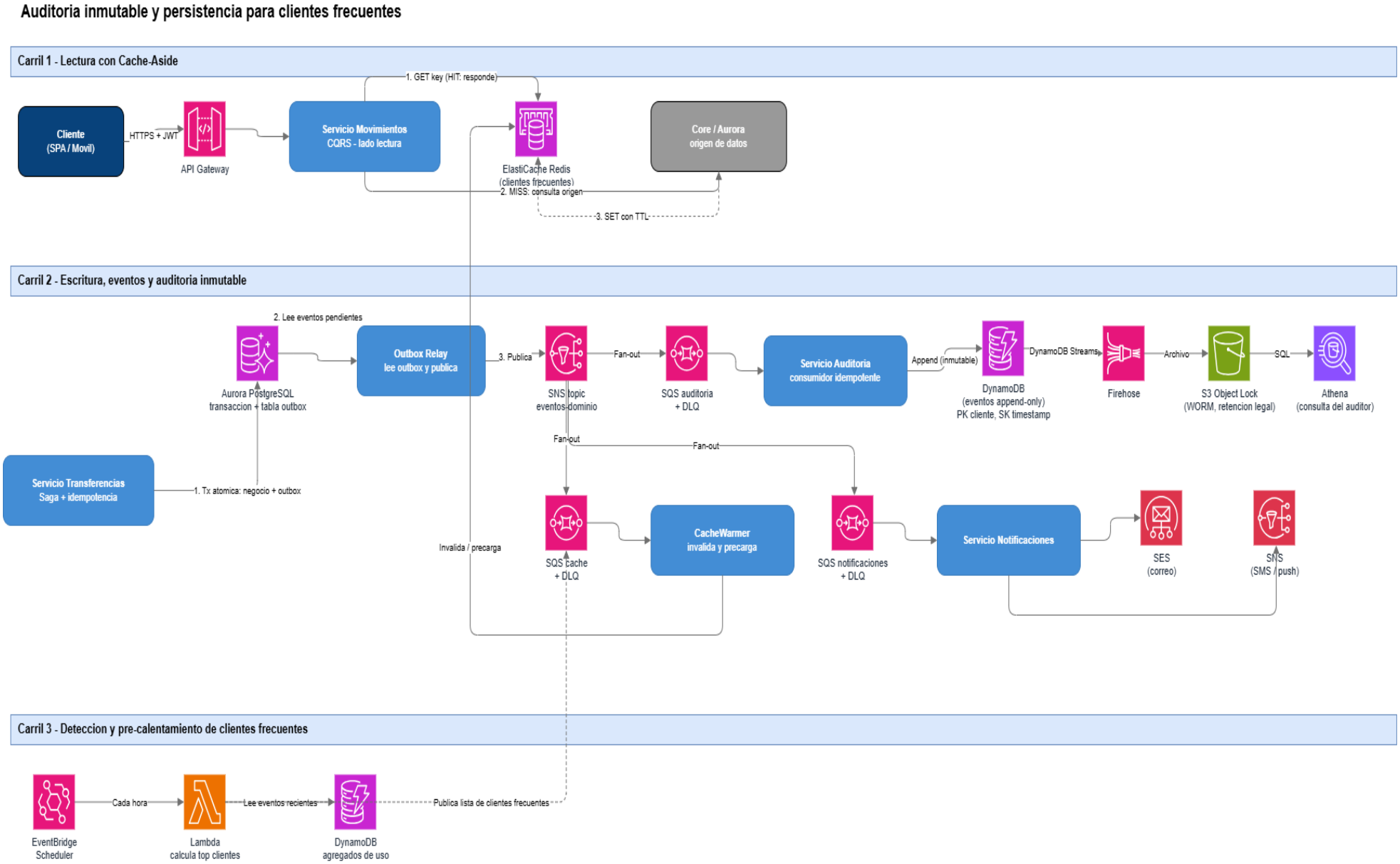
Componente	Alta disponibilidad (falla de zona)	Falla de región
Borde: Route 53, CloudFront, WAF, API Gateway	Servicios redundantes, sin impacto	Route 53 conmuta por health check; API Gateway por IaC
EKS y Keycloak	Nodos en 2+ AZ, topology spread, PDB, HPA; pods se reprograman	Clúster mínimo en DR que escala al activarse
Aurora PostgreSQL	Writer y reader en AZ distintas, failover automático	Global Database: promoción del secundario
ElastiCache Redis	Primario y réplica Multi-AZ	Se reconstruye y recalienta (es caché)
DynamoDB, S3, SNS, SQS	Multi-AZ nativo	Global Tables, replicación S3 y colas por IaC

Tolerancia a fallos: probes de liveness y readiness, autoescalado por CPU y por cola, Resilience4j en cada dependencia, DLQ con reproceso, despliegues canary con rollback y ejercicios de caos con Fault Injection Service. **DR:** Pilot Light / Warm Standby con RTO 1 h y RPO 5 min (supuestos), conmutación por Route 53, simulacros semestrales y pruebas de restauración trimestrales (D16).

Seguridad por capas: borde (WAF, Shield, CloudFront); red (VPC en 3 niveles de subred, security groups, VPC endpoints, sin salida a Internet en datos); identidad (OAuth 2.0, MFA, passkeys, IAM de mínimo privilegio); datos (TLS, KMS, Secrets Manager con rotación, tokenización); aplicación (SAST/DAST, escaneo de imágenes y dependencias, SBOM); detección (CloudTrail, GuardDuty, Security Hub, Config); antifraude (límites, atestación del dispositivo, step-up).

Monitoreo: CloudWatch con logs JSON sin datos sensibles, trazas con X-Ray u OpenTelemetry usando el trace-id, dashboards en Managed Grafana, SLO por servicio (disponibilidad, p95, errores) con alertas a guardia por SNS y runbooks, y señales de negocio (transferencias por minuto, lag de colas, aciertos de caché, fallas de onboarding) (D18). **Operación:** infraestructura como código con Terraform para ambas regiones y CI/CD con GitOps.

Figura 6. Infraestructura AWS: alta disponibilidad Multi-AZ y recuperación ante desastres



Costos

Estimación referencial en dólares con los volúmenes supuestos y precios de lista aproximados. São Paulo es de las regiones más costosas; debe validarse en AWS Pricing Calculator con datos reales de BP.

Grupo	Supuesto	USD / mes
Cómputo EKS (2 clústeres y 6 nodos con Savings Plan)	Primario más plano de control de DR	650 - 950
Aurora PostgreSQL (primaria y secundario Global)	Writer, reader y réplica de DR	1.050 - 1.700
ElastiCache Redis	2 nodos Multi-AZ	350 - 500
API Gateway, WAF, CloudFront, S3	~30 millones de solicitudes	180 - 360
Red: NAT, ALB, VPC endpoints	2 NAT y 1 ALB interno	150 - 250
Mensajería, DynamoDB, Firehose, Athena, Lambda	Eventos, auditoría y tareas	290 - 480
Rekognition, SES y SNS	~5.000 onboardings/mes y SMS variable	200 - 500
Observabilidad y seguridad	CloudWatch, X-Ray, Grafana, GuardDuty, KMS	300 - 600
Región de DR (Pilot Light)	Nodos mínimos y apoyo	400 - 800
Total sin Shield Advanced		aprox. 3.500 - 6.200
Total con Shield Advanced (3.000 fijos)		aprox. 6.500 - 9.200

Optimización: Savings Plans y Graviton, autoescalado y right-sizing trimestral, VPC endpoints para reducir tráfico por NAT, ciclo de vida en S3 respetando la retención legal, caché para bajar llamadas al Core, y etiquetado con AWS Budgets y revisión mensual (FinOps). Shield Advanced puede activarse después según el riesgo.

Matriz de decisiones arquitectónicas

Cada decisión indica lo elegido, las alternativas evaluadas y al menos dos justificaciones.

#	Decisión	Elegida	Alternativas	Justificación
D1	Estilo	Microservicios	Monolito modular; SOA con ESB	(1) Consultas, transferencias y notificaciones escalan por separado. (2) Una falla queda aislada. Costo: más operación, mitigada con EKS, IaC y observabilidad.
D2	Cómputo	Amazon EKS	ECS Fargate; Lambda	(1) Auto-healing, HPA y canary. (2) Aloja Keycloak y Spring Boot sin reescribir. Lambda sufre arranque en frío y conexiones a BD.
D3	Entrada	API Gateway + WAF	ALB con Kong/NGINX; AppSync	(1) JWT, throttling y validación gestionados. (2) Integración nativa con WAF y CloudWatch. (3) VPC Link mantiene privados los servicios.
D4	SPA	Angular	React; Vue	(1) Framework completo que homogeniza equipos grandes. (2) TypeScript estricto, carga diferida y seguridad de plantillas integrada.
D5	App móvil	Flutter	React Native; nativo	(1) Un código con rendimiento cercano al nativo y UI idéntica. (2) Biometría, almacenamiento seguro y cámara maduros; SDK nativos por canales. El nativo duplica el costo.
D6	Identidad	Keycloak en EKS	Cognito; Auth0/Okta	(1) OAuth 2.0, MFA y passkeys sin desarrollar la lógica. (2) Sin costo por usuario y datos en el perímetro de BP. (3) Extensible para el onboarding.
D7	Flujo OAuth	Auth Code + PKCE	Implicit; Password	(1) Recomendado por RFC 9700 y 8252. (2) El token no viaja en la URL y PKCE mitiga la interceptación.
D8	Reconocimiento facial	Rekognition	Proveedor KYC; open source	(1) Disponible en São Paulo (incluye Liveness) y gestionado. (2) Pago por uso y datos en la cuenta de BP. El KYC suma un tercero; el open source exige certificar el anti-spoofing.

D9	BD transaccional	Aurora PostgreSQL	RDS PostgreSQL; DynamoDB	(1) ACID y SQL para transferencias, idempotencia y outbox. (2) Failover Multi-AZ y Global Database para DR.
D10	Auditoría	DynamoDB + S3 Object Lock	OpenSearch; tabla relacional (QLDB discontinuado)	(1) Escritura append-only con latencia estable. (2) Object Lock compliance da inmutabilidad verificable. La tabla relacional compite con las transacciones.
D11	Caché	ElastiCache Redis	Memcached; caché local	(1) TTL por clave y réplicas Multi-AZ con failover. (2) Compartida entre pods, sin incoherencias. Memcached no replica.
D12	Mensajería	SNS + SQS con DLQ	MSK (Kafka); EventBridge	(1) Gestionado, Multi-AZ y de bajo costo. (2) El fan-out desacopla servicios. Kafka aporta replay pero más operación; se reevalúa si crece el volumen.
D13	Consistencia	Saga orquestada + Outbox	Saga coreografiada; 2PC; doble escritura	(1) 2PC no es viable con el Core ni la interbancaria. (2) La orquestación centraliza compensaciones y auditoría. (3) Outbox evita desalineación entre BD y bus.
D14	Estructura y resiliencia	Hexagonal + Resilience4j	Capas tradicionales; malla de servicios	(1) Aísla el dominio y permite pruebas sin infraestructura. (2) Circuit breaker y bulkhead declarativos por dependencia. La malla puede sumarse luego para mTLS.
D15	Notificaciones	SES + SNS	Proveedor externo; solo push	(1) Cumple 2 canales con redundancia. (2) Gestionados con reintentos y métricas; el servicio abstrae el canal.
D16	DR	Pilot Light / Warm Standby	Backup & Restore; Active-Active	(1) Equilibra RTO y costo. (2) Backup & Restore no cumple el RTO; Active-Active duplica costo y complejidad de escrituras.
D17	Región	sa-east-1 + DR us-east-1	us-east-1 o us-east-2 como primaria	(1) Región sudamericana con los servicios requeridos. (2) Separación geográfica clara con el DR. Contrapartida: mayor costo y latencia desde Ecuador, a medir.
D18	Observabilidad	CloudWatch, X-Ray, Grafana	Datadog/New Relic; ELK propio	(1) Integración nativa sin operar clústeres. (2) Trazas con correlación hasta la auditoría. Los SaaS suman costo y sacan datos del perímetro.